

Does a probability-led ranking find the vulnerabilities attackers later use? A point-in-time backtest of Stenwatch

Diljot Singh Johal · Stenwatch e7516c9 + uncommitted changes · run 2026-10-09 13:10

Abstract

Teams that patch from a CVSS list work through severity, and severity says how bad a flaw could be, not whether anyone is using it (Jacobs et al., 2019, p. 2). This report asks whether the scoring in Stenwatch, which leans on EPSS, points a team at the right vulnerabilities earlier. Six non-overlapping windows of 180 days were rebuilt from the data that existed on each start day, and the rankings were scored against the additions that CISA later made to its Known Exploited Vulnerabilities catalogue, 257 in all. The Attend queue held 6.1% of all CVEs and found 40% of the later-exploited ones, while the CVSS 9 and above list held 13.0% and found 36%. That difference is not statistically significant ($p = 0.329$). At equal queue size the Stenwatch ranking found clearly more, but it fell behind the CVSS ranking in the long tail. About 62% of CISA's additions concerned CVEs that were published after the window began, so no ranking could have found them early. An earlier result of about 70 percent was wrong and is withdrawn.

1. Introduction

Every year brings tens of thousands of new CVEs, and a security team can patch only a fraction of them. So the real question is never whether to prioritise but how. Consider a team that gets a list of several thousand "critical" findings on a Monday morning. Nobody reads that list, they read the top of it, and whatever sits there decides where the week goes.

The practice most teams know is to sort by CVSS. But how well does that sorting match what attackers really do? Jacobs et al. (2023, p. 1) report that only about 5 percent of known vulnerabilities are exploited in the wild, and they argue that strategies built on severity alone are poor predictors of exploitation. Stenwatch tries another route. It ranks by likelihood times impact, where likelihood comes from EPSS and impact from CVSS, and it adds context that a global score cannot hold, such as the organisation's own assets, CISA's catalogue and the threat groups it follows.

This report tests the part of that ranking that can be tested honestly, which is the global scoring signal. It does not test the asset list, the KEV flag or the threat-group matching, because none of them has a history that can be rebuilt for a past date. The study is a backtest and nothing more; it does not show that Stenwatch lowers real incident numbers, and it should not be read that way.

Section 2 gives the background, section 3 states the questions, and sections 4 and 5 describe the data and the method. Results follow in section 6, and the discussion, limits and threshold

sensitivity in sections 7 to 9. Section 10 explains how to rerun everything, and section 11 concludes.

2. Background

CVSS describes the severity of a flaw from its characteristics and its effect on confidentiality, integrity and availability. Its own specification is clear that the base score is not meant to reflect overall risk, and so it does not measure the probability that a flaw will be used in an attack (Jacobs et al., 2019, p. 2). Still, it became the common yardstick, and some rules lean on it directly, for example the payment card standard that requires flaws above 4.0 to be fixed (Jacobs et al., 2019, p. 2).

EPSS answers the other half of the question. The first version estimated the probability that a flaw would be exploited in the wild within twelve months of disclosure (Jacobs et al., 2019, p. 1). The third version estimates the probability of exploitation activity in the next 30 days, and scores are produced daily (Jacobs et al., 2023, pp. 2, 6). That daily file is what makes a backtest possible, because the score of any past day can be downloaded again.

The evidence for the answer key comes from CISA. Its Known Exploited Vulnerabilities catalogue is described by CISA as "the authoritative source of vulnerabilities that have been exploited in the wild" (CISA, n.d.), and each entry carries the date it was added. Jacobs et al. (2023, p. 3) themselves use the catalogue as one input among several exploitation sources, and they saw exploitation activity for 6.4 percent of 192,035 published vulnerabilities between 2016 and 2022.

Two earlier results frame what to expect. First, Jacobs et al. (2019, p. 14) compared the effort needed to reach the same coverage as a CVSS strategy and found that EPSS needed far less, for instance 181 vulnerabilities against 813 to match the coverage of CVSS 9 and above, a reduction of 77.7 percent. Second, they define efficiency as the share of prioritised vulnerabilities that were exploited, and coverage as the share of exploited vulnerabilities that were prioritised (Jacobs et al., 2023, p. 6). This report uses the same two ideas under the names hit rate and recall.

Term	Meaning
CVE	A public identifier for one software vulnerability, such as CVE-2024-12345.
CVSS	A 0 to 10 severity score for how bad a flaw could be. It says nothing about whether anyone is using it.
EPSS	A 0 to 1 probability, published daily by FIRST, that a CVE will be exploited in the next 30 days.
KEV	CISA's catalogue of vulnerabilities known to be exploited in the wild. Used here as the answer key.
Queue	The CVEs a rule selects for attention, for example every CVE with EPSS at or above 0.1.
Recall	Of the CVEs that were later exploited, the share a queue contained (coverage in Jacobs et al., 2023).
Hit rate	Of the CVEs in a queue, the share that were later exploited (efficiency in Jacobs et al., 2023). Lift is the hit rate divided by the base rate.
Review budget	How far down a ranked list a team can read, as a share of all CVEs.

3. Research questions and hypotheses

The main question is whether the Stenwatch ranking would have pointed a team at vulnerabilities attackers went on to use, with less reading than the usual CVSS list needs. Two hypotheses were written down before the run on complete data.

H1 says that a ranking by EPSS times CVSS finds later-exploited CVEs with less review effort than a ranking by CVSS alone. The verdict is **Partly supported**. It holds at small review budgets, meaning the first 1, 5 and 10 percent of the list, but not over the whole list, because CVSS reaches 80 percent sooner and has the higher AUC.

H2 says that the Attend queue catches more later-exploited CVEs than a critical-severity queue of similar or smaller size. The verdict is **Partly supported**. Attend caught 40% against 36%, which is not a significant difference, from a queue 2.1 times smaller. So "catches more" is not shown, but "catches as many from far less" is.

The first, exploratory run suggested stronger results than these (see the correction in section 4). The windows, thresholds and measures were fixed before the complete-data run and were not changed afterwards, and the thresholds are the product's own defaults from `profile.example.yaml`, not values tuned on this data. The equal-size comparison in section 6.5 is the exception. It was added after the first results, because comparing queues of different size is unfair to both, so it is exploratory.

4. Data and provenance

Data	What it is	Used for	Point in time
EPSS daily files	FIRST's exploit-probability score for every CVE, one file per day from epss.empiricalsecurity.com. Six snapshots, one per window start, with the SHA-256 of each in section 10.	Ranking score	Yes, the file of the origin day
CISA KEV catalogue	1,739 entries, first added 2021-11-03, latest 2026-10-08, with the date each CVE was added.	Labels, meaning what counts as exploited and when	Yes, the date added decides the window
NVD CVE records	400,841 CVEs, latest published 2026-10-09. CVSS is the first available of v4.0, v3.1, v3.0 and v2 as stored by Stenwatch.	Severity and publication date	Publication date yes, CVSS is today's value

All three feeds are public and were downloaded with Stenwatch's own collector (`cti/collect.py`). The gap fill described below used `tools/nvd_fill.py`, which calls the same parser. CVEs with no CVSS score, 24,825 across all windows or 1.6%, are treated as severity 0, which can only hurt the CVSS baselines.

A correction and a data audit. An earlier exploratory run reported that the Attend queue caught about 70 percent of later-exploited CVEs against about a third for the critical list. That result is withdrawn. It came from a local database that was missing most CVEs published in 2024 and 2025, only 26 and 869 records, which silently removed the hardest-to-find exploited CVEs from the test. The database was then completed, and the self-check in section 10 now refuses to run if either year holds fewer than 30,000 CVEs. Records per year in the database used were 2022 with 26,431, 2023 with 28,352, 2024 with 40,704, 2025 with 49,972, 2026 with 78,161. Please do not quote the 70 percent figure anywhere.

5. Method

5.1 Design

The test uses six consecutive windows of 180 days that do not overlap (figure 1), so that one exploited CVE is never counted twice. At each origin date T_0 the situation of a team on that day is rebuilt, which means which CVEs existed, how severe they looked, what EPSS said and which were already known to be exploited. Then the next 180 days are read to see which CVEs CISA added.

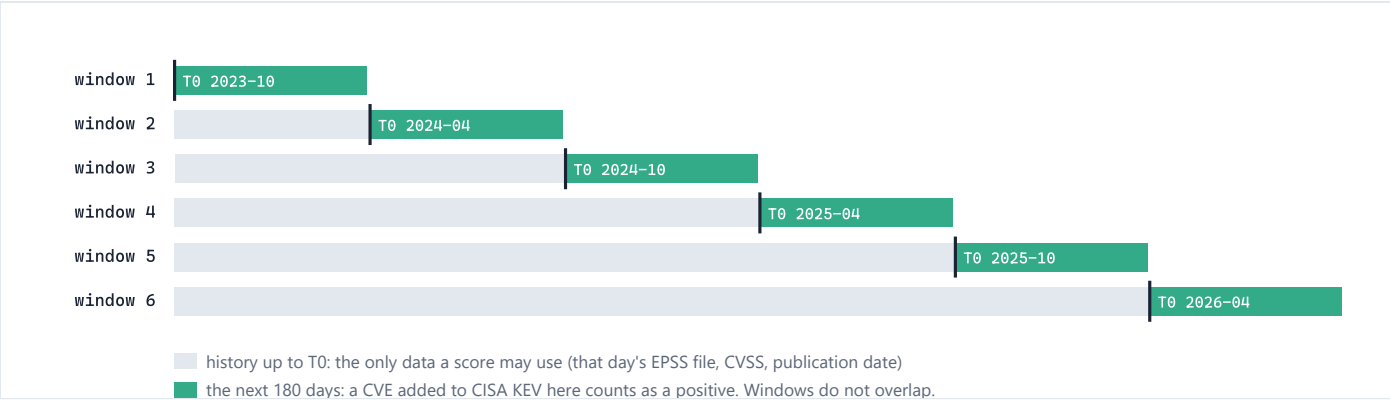


Figure 1. Backtest design. Grey is the history available at T0, green the 180 days used to label outcomes.

5.2 Population and labels

The population at T0 is every CVE published on or before T0 that has an EPSS score on that day and is not yet in KEV. Already-exploited CVEs are left out, since ranking something already known is not a prediction; a positive is a member of that population that CISA added during the next 180 days; every other member is a negative.

Of the 711 CVEs added to KEV during the six windows, 257 (36%) are in scope; the rest could not be scored on the origin day, because 444 were published after T0, 9 are missing from the NVD copy and 1 had no EPSS score on T0.

5.3 What is compared

Name	How it works
Stenwatch score	EPSS times CVSS, the part of the product's risk formula that can be reproduced without KEV, threat-group or asset information. The weights are constants and do not change the order.
EPSS alone	Rank by exploit probability.
CVSS alone	Rank by severity, which is what most vulnerability lists do.
Attend queue	EPSS at or above 0.1, the product's Attend threshold for CVEs not yet known to be exploited.
Attend and Track queue	EPSS at or above 0.01, or CVSS at or above 7.0.
CVSS 9 and above, CVSS 7 and above	The two severity lists that teams commonly work from.

5.4 Measures and statistics

Each queue is judged on its recall and its size, since size is the review cost, and on its hit rate and lift. Each ranking is judged on a gain curve (figure 3), which plots recall against the share of the list read, on the reviews needed to find 50 and 80 percent of the positives, and on ROC

AUC, the chance that a random positive is ranked above a random negative, where 0.5 means no skill and 1 means a perfect ranking.

CVSS has few distinct values, so many CVEs tie. Ties are resolved by their expected value under random order, which is exact and needs no random seed; the AUC gives half credit to ties. Pooled recall carries 95 percent Wilson score intervals, chosen because the Wilson interval keeps its coverage better than the simple textbook interval when counts are small (Brown et al., 2001, p. 101). Two queues are compared on the same positives, so the difference is tested only on the positives that one of them caught and the other missed, with an exact two-sided binomial test, also known as the sign test. Across windows the AUC is reported as mean and standard deviation, and no test is applied there because six windows are too few.

5.5 Safeguards against looking ahead

Risk	What was done
Using today's EPSS	Each window uses that origin day's own EPSS file.
Using later KEV knowledge	CVEs already in KEV on T0 are removed, and only the date added decides outcomes. The KEV flag is never used as a feature.
Using CVEs that did not exist	Only CVEs published on or before T0.
Tuning on the answer	Thresholds are the product's defaults, fixed before the run, and section 9 shows how results move if they change.
CVSS revisions	CVSS is today's NVD value, because scores at T0 are not stored. The possible effect is discussed in section 8.

6. Results

6.1 The windows

Origin	Population	Positives	KEV additions	Base rate
2023-10-01	212,884	35	87	0.016%
2024-04-01	237,010	31	88	0.013%
2024-10-01	256,907	49	127	0.019%
2025-04-01	269,000	36	104	0.013%
2025-10-01	292,358	59	133	0.020%
2026-04-01	320,064	47	172	0.015%
Pooled	1,588,223	257	711	0.016%

The base rate is the chance that a random, not-yet-exploited CVE is added to KEV within six months, and it is about 0.016%. Reading in random order would find 1 percent of the positives per 1 percent of effort; every result below is measured against that.

6.2 Queues

Queue	Size (share of CVEs)	Positives caught	Recall (95% interval)	Hit rate	Lift over random
Stenwatch Attend (EPSS ≥ 0.1)	6.1%	103 of 257	40% (34% to 46%)	0.106%	6.5x
Stenwatch Attend + Track (EPSS ≥ 0.01 or CVSS ≥ 7.0)	54.9%	232 of 257	90% (86% to 93%)	0.027%	1.6x
CVSS ≥ 9 (critical)	13.0%	92 of 257	36% (30% to 42%)	0.044%	2.7x
CVSS ≥ 7 (high and critical)	48.2%	220 of 257	86% (81% to 89%)	0.029%	1.8x

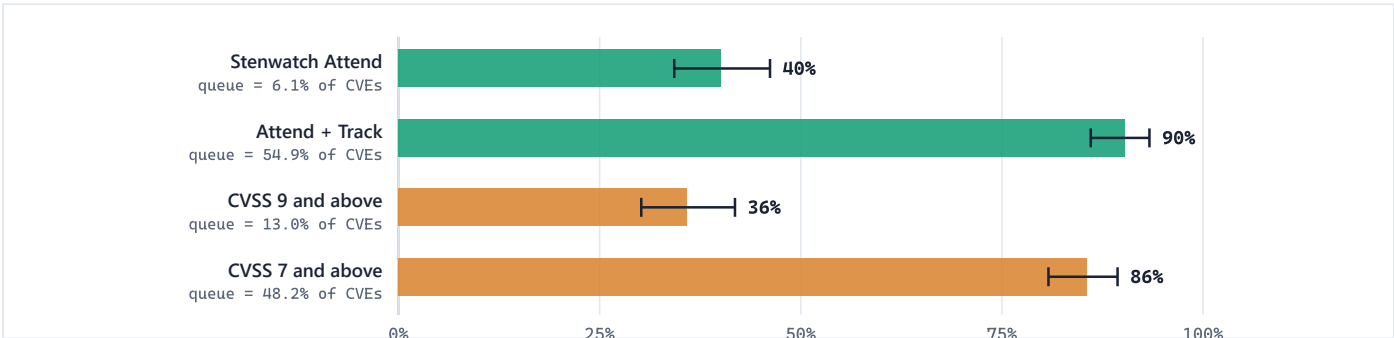


Figure 2. Recall of each queue, pooled over six windows, with 95 percent intervals.

The Attend queue is small and efficient, but it is not more complete than the critical list; it holds 6.1% of all CVEs and found 40% of the later-exploited ones (95% interval 34% to 46%). The CVSS 9 and above list holds 13.0% and found 36% (30% to 42%). That makes Attend 2.1 times smaller; each CVE read is 2.4 times as likely to be a hit.

The paired comparison on the same 257 positives shows why the difference is not significant.

	Caught by CVSS 9+	Missed by CVSS 9+
Caught by Attend	45	58
Missed by Attend	47	107

Attend found 58 exploited CVEs that the critical list missed, and the critical list found 47 that Attend missed (exact test, $p = 0.329$). The two queues largely catch different CVEs; neither contains the other. Against the much larger CVSS 7 and above list, Attend found 8 that the list missed and missed 125 that it found (p below 0.001), and that list is 7.9 times the size of the Attend queue.

6.3 Rankings

Ranking	AUC (mean $\pm$ SD, 6 windows)	Reviews to find 50%	Reviews to find 80%	Found in the first 1%	Found in the first 5%	Found in the first 10%
Stenwatch score (EPSS x CVSS)	0.720 $\pm$ 0.055	10.5%	58.2%	21%	37%	46%
EPSS alone	0.692 $\pm$ 0.064	10.4%	70.4%	19%	37%	47%
CVSS alone	0.744 $\pm$ 0.037	20.1%	42.5%	2%	13%	30%

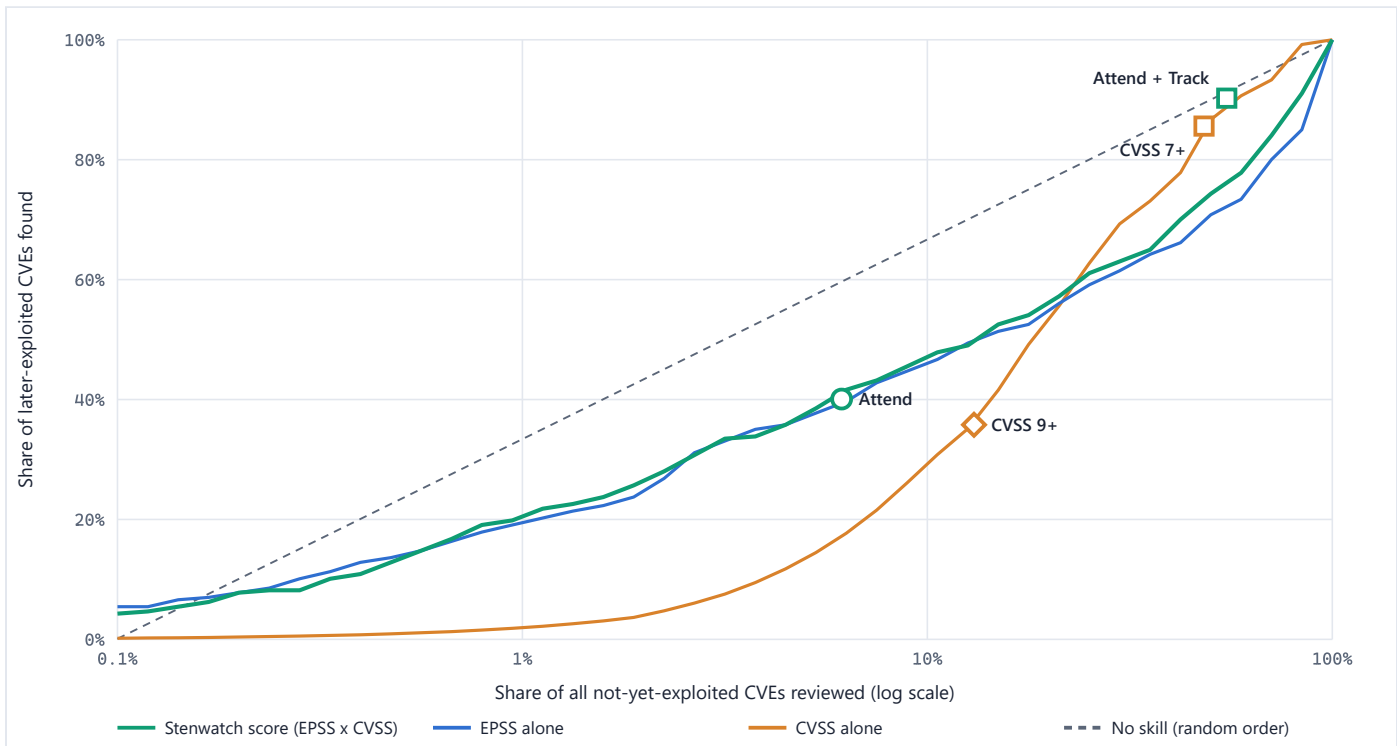


Figure 3. Gain chart. A curve that rises sooner means less work to find the same share of exploited CVEs. The four marked points are the queues of section 6.2.

After the first 1 percent of the list the Stenwatch score has found 21% of the exploited CVEs against 2% for CVSS, and after 10 percent it is 46% against 30%. But to reach 80 percent, CVSS needs 42.5% of the list and the Stenwatch score 58.2%. The two gain curves cross at about 25% of the list: reading further than that, the CVSS ranking is ahead. The overall AUC is 0.744 for CVSS and 0.720 for the Stenwatch score.

6.4 Consistency across windows

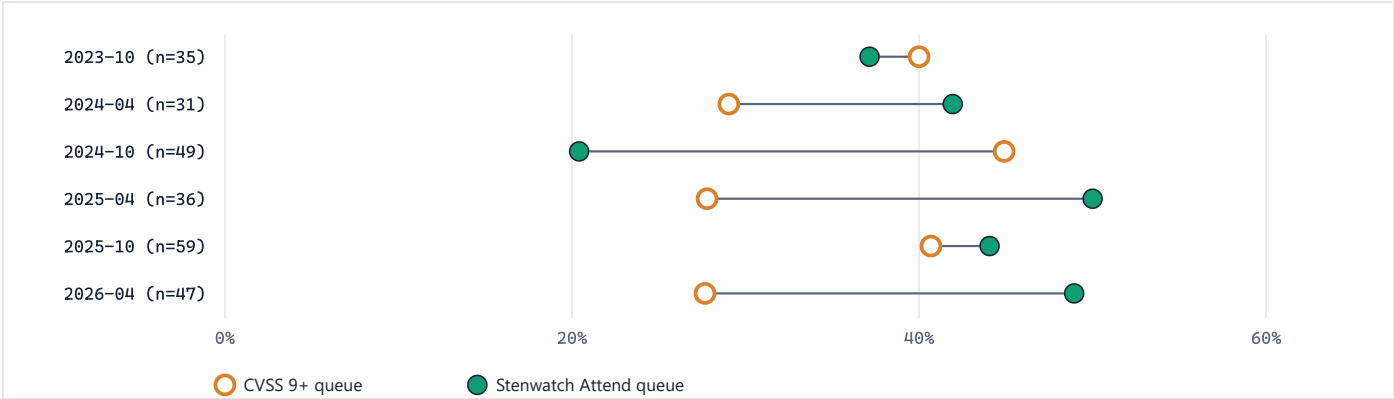


Figure 4. Recall of the Attend queue against the CVSS 9+ queue in each window, where n is the number of positives. Attend was higher in 4 of 6 windows.

6.5 At equal queue size (exploratory)

Queues of different size are hard to compare. So here every ranking is read down to exactly the size of each queue, and its recall is shown beside the queue's own.

Queue size set by	Share of CVEs	Stenwatch score ranking	EPSS ranking	CVSS ranking	The queue itself
Stenwatch Attend	6.1%	41%	40%	16%	40%
CVSS 9 and above	13.0%	50%	49%	36%	36%
CVSS 7 and above	48.2%	72%	70%	86%	86%
Attend + Track	54.9%	76%	72%	89%	90%

Up to a queue the size of the critical list, a probability-led ranking finds many more exploited CVEs than a severity ranking, 50% against 36%. At the size of the large lists the CVSS ranking is ahead, with 86% against 72% at the size of the CVSS 7+ list. The Attend and Track queue, at 90%, is no better than simply reading the CVSS ranking to the same size, which gives 89%.

6.6 Why severity wins in the tail

45% of the later-exploited CVEs had an EPSS score under 0.01 on the origin day. They sit at the bottom of any probability ranking and are reached only by reading very far down it; severity does not depend on earlier exploitation signals, which is why it recovers them late. This is the argument for keeping a severity-based second pass behind the Attend queue.

7. Discussion

What does this mean for a team that today works down a CVSS list? The first answer is about effort. Jacobs et al. (2019, p. 14) found that EPSS matched the coverage of CVSS 9 and above with 77.7 percent less effort. This backtest, on later data and with the product's own thresholds, agrees on the direction but not on the size. At the size of the critical list the Stenwatch ranking

found 50% against 36%, which is a clear gain, and the Attend queue matched the critical list's coverage from a queue 2.1 times smaller. That is a real saving, but nowhere near a free lunch.

The second answer is about what the ranking cannot do. About 62% of the 711 CVEs that CISA added during the windows had not even been published on the origin day, so they are out of reach of any ranking and are caught only once CISA lists them. This report therefore reads the result in two parts. The probability ranking decides where to look first, and the KEV feed, which drives the Act tier, covers what nobody could predict.

The third answer is a warning. 60% of later-exploited CVEs sit outside the Attend queue, and many of them are the ones with a very low EPSS on the day. A team that reads Attend and stops will miss them. Hence the Track tier exists; the result of section 6.5 shows it is only as good as a plain severity list of the same size, so its value is that it is cheap to keep, not that it is clever.

Stenwatch should be treated as a way to start the reading in the right place. It is not a replacement for the second pass.

8. Threats to validity and limits

KEV is a proxy for exploited. CISA lists vulnerabilities with evidence of exploitation that are relevant to its mission and carry remediation guidance, so exploited CVEs it never lists count here as negatives, and the test measures agreement with CISA's list and nothing wider.

Only CVEs that existed on T0 can be scored; as said above, 62% of KEV additions in these windows were published after T0.

The positives are few, 257 in total and between 31 and 59 per window, so single-window figures are noisy; the pooled intervals assume positives are independent. But exploited CVEs often cluster in one product, so the true uncertainty is somewhat larger than the intervals show.

EPSS changed model version during the period, so scores are not perfectly comparable across windows, and section 9 shows the sensitivity to the threshold. CVSS is also today's value, and NVD revises scores after publication. If revisions are more likely for CVEs that later prove important, severity is slightly flattered, and that bias would favour the CVSS baselines, not Stenwatch.

Several things are not tested here. The KEV flag, ransomware use, threat-group overlap, asset criticality, internet exposure and supplier context have no point-in-time history, and in use they act on top of the ranking. This report tests the part that can be tested; finally, the queues cover all CVEs. In use, Stenwatch first filters to the organisation's own assets, which shrinks the queue by orders of magnitude, so the ranking quality measured here carries over but the percentages do not.

9. Sensitivity to the thresholds

Moving the EPSS threshold trades queue size against recall along one curve (figure 5). Lowering the default of 0.1 to 0.05 would add 2.9% of all CVEs to the queue and 4 points of recall, and raising it to 0.2 would remove 2.1% of CVEs and 5 points of recall.

EPSS at or above	Queue (share of CVEs)	Recall
0.005	30.35%	60%
0.01	20.60%	55%
0.02	14.38%	50%
0.05	9.02%	44%
0.1 (default)	6.14%	40%
0.2	4.09%	35%
0.3	3.16%	33%
0.5	2.19%	26%

CVSS at or above	Queue (share of CVEs)	Recall
5	82.8%	99%
6	64.3%	93%
7	48.2%	86%
8	22.6%	59%
9	13.0%	36%
9.5	9.9%	30%

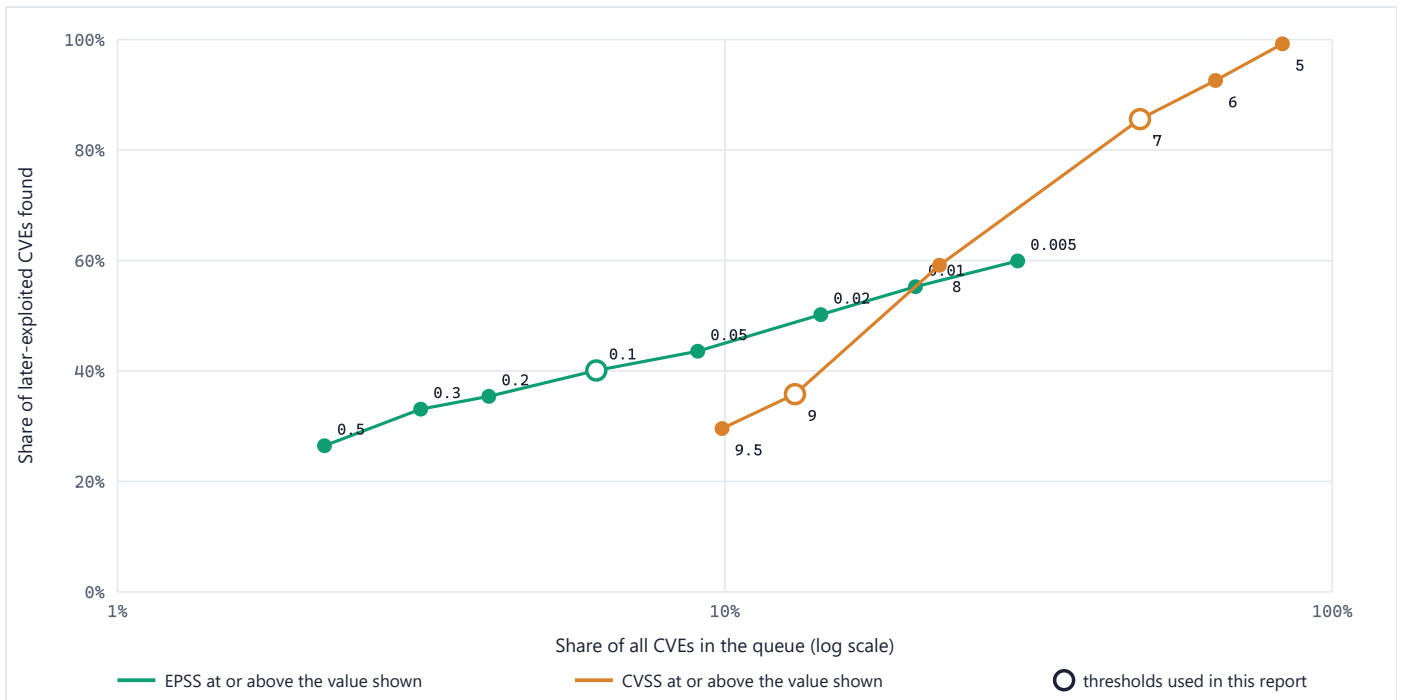


Figure 5. Recall against queue size as each threshold moves. Ringed points are the thresholds used in this report.

10. Reproducibility and checks

Everything is regenerated by commands run from the repository root. The command `python tools/backtest.py` downloads six EPSS files and writes `docs/backtest/results.json`, which takes about a minute once the database is complete, and `python tools/backtest_report.py` then writes this report. The statistics have unit tests with hand-worked answers, run with `python tools/test_backtest.py`. A database that is missing years can be completed with `python tools/nvd_fill.py 2024-01-01 2026-10-09`.

Check	Result
every EPSS snapshot has more than 150,000 scored CVEs	passed
every window has at least 20 positives	passed
no CVE appears twice in a population	passed
positives are a subset of the KEV additions of the window	passed
the six windows do not overlap	passed
Attend queue recall computed by rule equals recall computed through the ranking code (difference < 0.5 positive per window)	passed
a perfect ranking would reach AUC 1 and a tie-only ranking AUC 0.5 (unit tests in tools/test_backtest.py)	passed
queue sizes shrink as thresholds rise (monotone sweeps)	passed
pooled recall never exceeds 1 and the 100 % budget finds every positive	passed
database has complete NVD coverage for 2024 and 2025 (more than 30,000 CVEs per year)	passed

Window origin	EPSS file SHA-256	Rows
2023-10-01	8cad499a66bb048338433f51...	213,894
2024-04-01	c5437dbc2337ea973253ee65...	240,713
2024-10-01	f4ffadaf781caad7dcf6c9b7...	260,671
2025-04-01	87d6744e6bc7b5e3b05095d6...	272,867
2025-10-01	d8a34baffdb8dedfe6c3ce06...	296,333
2026-04-01	1ebc89bb171e7ca54b217c5e...	324,173

Software used was Python 3.14.2 and NumPy 2.5.3, at code revision e7516c9 + uncommitted changes.

11. Conclusion and next steps

Use Attend as the first-pass queue. It is 2.1 times smaller than the critical list, it finds about as many later-exploited CVEs, and each CVE read is 2.4 times as likely to matter. But do not stop there, because about 60% of later-exploited CVEs sit outside it, and a severity-ordered second pass should stay behind it for as long as capacity allows.

The KEV feed has to stay fresh, since 62% of CISA additions concern CVEs that did not exist six months earlier; the backtest should be rerun every quarter, because new windows add positives and show whether EPSS model changes move the thresholds, and the commands in section 10 take minutes. Labels that do not depend on CISA, such as public exploit code or vendor

advisories that note exploitation, would reduce the proxy problem. The local part, meaning asset context, cannot be backtested globally and has to be measured on the organisation's own incidents and patch decisions.

Declaration

The analysis code, the runs and the figures are the author's own. An AI assistant was used during drafting and code review, and every number in this report is generated from results.json by tools/backtest_report.py, so the text cannot disagree with the data.

References

- Brown, L. D., Cai, T. T. and DasGupta, A. (2001). Interval estimation for a binomial proportion. *Statistical Science*, 16(2), 101 to 133. <https://doi.org/10.1214/ss/1009213286>
- CISA (n.d.). Known Exploited Vulnerabilities Catalog. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (accessed 9 October 2026).
- FIRST (n.d.). Exploit Prediction Scoring System, daily score files. <https://epss.empiricalsecurity.com/> (daily snapshots as listed in section 10).
- Jacobs, J., Romanosky, S., Edwards, B., Roytman, M. and Adjerid, I. (2019). Exploit Prediction Scoring System (EPSS). arXiv:1908.04856. Page numbers refer to the arXiv PDF.
- Jacobs, J., Romanosky, S., Suciu, O., Edwards, B. and Sarabi, A. (2023). Enhancing vulnerability prioritization, data-driven exploit predictions with community-driven insights. arXiv:2302.14172v2. Page numbers refer to the arXiv PDF.
- NIST (n.d.). National Vulnerability Database, CVE records and CVSS scores. <https://nvd.nist.gov/>

Appendix. Per-window detail

Origin	Queue	Size	Positives caught	Recall
2023-10-01	Stenwatch Attend	11,880	13 of 35	37%
2023-10-01	CVSS 9 and above	29,907	14 of 35	40%
2024-04-01	Stenwatch Attend	11,982	13 of 31	42%
2024-04-01	CVSS 9 and above	31,471	9 of 31	29%
2024-10-01	Stenwatch Attend	12,368	10 of 49	20%
2024-10-01	CVSS 9 and above	33,218	22 of 49	45%
2025-04-01	Stenwatch Attend	19,806	18 of 36	50%
2025-04-01	CVSS 9 and above	35,357	10 of 36	28%
2025-10-01	Stenwatch Attend	20,151	26 of 59	44%
2025-10-01	CVSS 9 and above	37,373	24 of 59	41%
2026-04-01	Stenwatch Attend	21,365	23 of 47	49%
2026-04-01	CVSS 9 and above	39,799	13 of 47	28%

Stenwatch by Diljot Singh Johal · MIT licence · feed data belongs to FIRST, CISA and NIST.